

セキュリティ実践演習第一最終報告書.

学籍番号: 25Y0009 氏名: Davaakhuu Undarmaa

1. はじめに

本報告書では、九経連の実践インターンシップおよび大学内で実施されたセキュリティ実践演習第一におけるセキュリティに関連する演習および、九経連の実践インターンシップについてまとめるの活動を報告する。

2. セキュリティ実践演習第一演習

本演習では、情報セキュリティに関する理論だけでなく、実際のシステムやツールを利用した実践的な知識と技術を身につけることを目的としている。セキュリティ実践演習として、公開鍵認証基盤（PKI）演習、マルウェア解析演習、インシデントレスポンス演習の3つのテーマに取り組んだ。次節では、それぞれの演習内容と取り組み結果について報告する。公開鍵認証基盤（PKI）演習では、公開鍵暗号方式を用いた認証の仕組みやデジタル証明書の役割について理解し、安全な通信を実現するための基盤技術について学んだ。また、マルウェア解析演習では、実際のマルウェアデータセットを用いた分析や特徴量の確認、機械学習を利用した分類などを通して、マルウェアの検知と分析の基本的な手法について学習した。

2.1 公開鍵認証基盤(PKI)演習

公開鍵認証基盤（PKI）演習では、プライベート CA を構築して、公開鍵暗号方式を利用した認証の仕組みやデジタル証明書の役割について理解し、安全な通信を実現するための基盤技術について学習した。

2.1.1 公開鍵認証基盤(PKI)

PKI（Public Key Infrastructure）は、公開鍵暗号方式を利用して安全な通信を実現するための仕組みである。インターネットでは、HTTPS 通信や電子商取引、クラウドサービスなどにおいて広く利用されている。PKI を利用することで、通信の暗号化だけ

でなく、サーバ証明書を検証することで通信相手が正しいサーバであることを確認することができる。

PKI の構成要素を以下に示す。

(1) 認証局 (CA: Certificate Authority)

認証局はサーバ証明書を発行し、その正当性を保証する機関である。CA は証明書を発行する前にドメインや組織情報を確認し、信頼できることを証明する役割を持つ。また、PKI では最上位の認証局としてルート CA (Root Certificate Authority) が存在し、他の認証局や証明書の信頼の基点となる。

(2) サーバ証明書

サーバ証明書は Web サーバの公開鍵やドメイン名情報 (FQDN) を含むデジタル証明書であり、クライアントが接続先のサーバの正当性を確認するために使用される。

(3) 公開鍵と秘密鍵

PKI では公開鍵暗号方式を使用する。公開鍵は外部に公開され、データの暗号化などに利用される。一方、秘密鍵はサーバ側で安全に管理され、暗号化されたデータを復号するために使用される。

(4) ルート証明書

ルート証明書は認証局の最上位の証明書であり、ブラウザや OS にあらかじめ登録されている。クライアントはこのルート証明書を基準として証明書の信頼性を確認する。

(5) 証明書チェーン

証明書チェーンはサーバ証明書からルート証明書までの信頼関係を示すものであり、クライアントはこのチェーンを検証することで通信相手の信頼性を確認する。

2.1.2 プライベート CA による構築サーバ証明書署名演習

演習用ネットワーク上でプライベート CA を構築し、サーバ証明書を発行して署名することで、PKI の仕組みについて実践的に学習した。

演習では、2 台の仮想サーバ (Ubuntu 24.04 LTS) と 1 台のノート PC (Ubuntu 24.04 LTS) を用いて環境を構築した。ネットワーク環境として、プライベートネットワーク (ドメイン名 : example.jp, 10.0.0.0/24) が提供された。まず、CA サーバ

(pki.example.jp) において OpenSSL を用いて CA の秘密鍵を生成し, ルート証明書を作成した。次に, Web サーバ (www1.example.jp) において公開鍵と秘密鍵を生成し, 公開鍵を含む CSR (Certificate Signing Request) を作成した。作成した CSR を CA サーバに送信し, CA の秘密鍵を用いてサーバ証明書を発行した。

発行されたサーバ証明書は Web サーバの Apache HTTPd の設定ファイルで指定した。また, クライアント (ノート PC) ではプライベート CA のルート証明書を信頼ストアに登録することで証明書チェーンを検証できる。これにより, TLS ハンドシェイクを通して安全な通信が確立される。

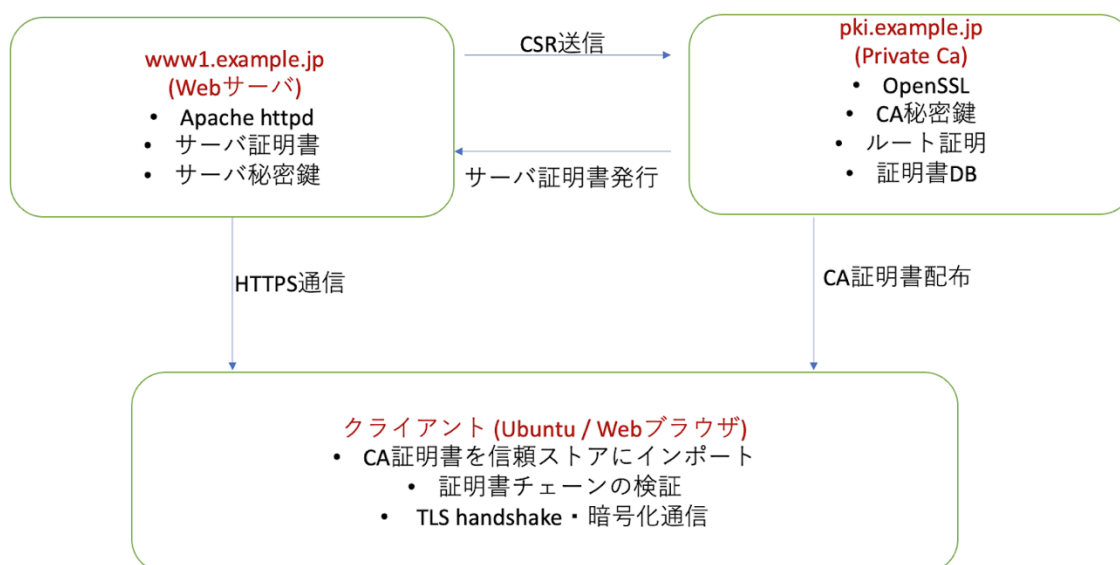


図 1 : Private CA の構成と証明書発行の流れ

処理フロー およびコマンドを以下に示す。

1. CA サーバで CA 秘密鍵を生成
2. CA サーバでルート証明書を作成
3. Web サーバでサーバ秘密鍵およびサーバ公開鍵の鍵ペアを生成
4. Web サーバで CSR (Certificate Signing Request) を作成
5. Web サーバから CA サーバへ CSR を送信
6. CA サーバにおいて申請者の本人確認および証明書発行の審査を行う
7. CA サーバで CSR に署名し、サーバ証明書を発行

8. CA サーバから Web サーバへサーバ証明書を送付
9. Web サーバで Apache httpd の設定ファイルにサーバ証明書、サーバ秘密鍵、および中間証明書を指定
10. Web サーバで Apache httpd サービスを再起動
11. クライアント側で CA 証明書（ルート証明書）を信頼ストアにインポート
12. クライアント側で CA 証明書（ルート証明書）を信頼ストアにインポート
13. クライアントから Web サーバ（https://www1.example.jp/）へ HTTPS 接続を行う。
14. TLS ハンドシェイクにおいて、証明書チェーンの検証を行う。
15. 暗号化通信が確立される。

example.jp ドメイン配下に、DNS 権威兼 DNS キャッシュサーバ（localdns.example.jp）、プライベート CA サーバ（pki.example.jp）、Web サーバ（www1.example.jp）を配置し、これらを同一ネットワークセグメント（10.0.0.0/24）上で構成した。クライアントとして Ubuntu ノート PC を用い、無線 LAN)にて、演習用ネットワークに接続した。

2.1.3 HTTPS 接続時に確認したサーバ証明書情報

演習では、自身が構築した Web サーバに対して HTTPS 接続を行い、openssl コマンドおよび証明書生成時のログからサーバ証明書の情報を確認した。

```
Using configuration from /home/security/easy-rsa/pki/openssl-easyrsa.cnf
Enter pass phrase for /home/security/easy-rsa/pki/private/ca.key:
Check that the request matches the signature
Signature ok
The Subject's Distinguished Name is as follows
countryName             :PRINTABLE:'JP'
stateOrProvinceName     :ASN.1 12:'Oita'
localityName            :ASN.1 12:'Oita'
organizationName        :ASN.1 12:'Oita University'
organizationalUnitName   :ASN.1 12:'Community'
commonName               :ASN.1 12:'www1.example.jp'
emailAddress             :IASSTRING:'v25y0009@oita-u.ac.jp'
Certificate is to be certified until Mar 28 04:27:21 2028 GMT (825 days)

Write out database with 1 new entries
```

図 2：Private CA によるサーバ証明書署名処理のログ

- 証明書の発行者 (Issuer)

本 Web サーバで使用したサーバ証明書は、easy-rsa を用いて構築した Private CA により発行された。Issuer:CN=Easy-RSA CA, O=Oita University, C=JP

また、証明書生成時のログにおいて CA の秘密鍵 (ca.key) を用いて署名処理が行われていることを確認した。

```
[Using configuration from /home/security/easy-rsa/pki/openssl-easyrsa.cnf
```

```
Enter pass phrase for /home/security/easy-rsa/pki/private/ca.key
```

```
Signature ok]
```

このことから、本サーバ証明書は構築した Private CA によって正しく発行されたことが確認できる。

- 有効期限 (Validity)

サーバ証明書の有効期限は以下の通りである。

Certificate is to be certified until Mar 28 04:27:21 2028 GMT (825 days)

この結果から、本証明書は発行日から約 825 日間有効であることが確認できる。

演習では、自身が構築した Web サーバに対して HTTPS 接続を行い、openssl コマンドおよび証明書生成時のログからサーバ証明書の情報を確認した。

本演習を通して、PKI の基本的な仕組みと証明書発行の流れについて理解を深めることができた。特に、CA による証明書の発行や証明書チェーンの検証プロセスを実際に体験することで、PKI が安全な通信の実現において重要な役割を果たしていることを理解した。また、発展的な内容について検討した結果を以下に示す。

2.1.4 実運用を想定した考察

- 公開 CA とプライベート CA の使い分け

実運用環境においては、すべてのシステムに対して単一の CA を利用するのではなく、利用目的やアクセス主体に応じて公開 CA とプライベート CA を適切に使い分ける設計が重要である。まず、学外ユーザや不特定多数の利用者がアクセスする公開 Web サイトや EC サイトでは、主要な OS や Web ブラウザにあらかじめ信頼されている公開 CA を利用することが必要である。これにより、クライアント側で証明書警告が表示されることを防ぎ、高い信頼性と利便性を確保できる。

一方で、学内システムや内部 API、VPN 接続、IoT デバイス間通信など、利用範囲が限定されている環境では、プライベート CA の利用が適している。プライベート CA を利用することで、証明書発行の迅速化やコスト削減、さらに組織独自の命名規則や有効期間の設定など、柔軟な運用が可能となる。

- 証明書失効管理（CRL / OCSP）

プライベート CA を利用する場合、証明書の失効管理が重要となる。もしサーバ証明書や秘密鍵が漏えいした場合、速やかに証明書を失効させなければ、中間者攻撃（MITM）などの重大なセキュリティリスクが発生する可能性がある。CRL（Certificate Revocation List）は、失効した証明書の一覧を定期的に配布する方式であり、構成が比較的単純で実装しやすい。一方で、証明書数が増加すると配布データのサイズが大きくなるという課題がある。これに対して OCSP（Online Certificate Status Protocol）は、証明書の有効性をリアルタイムで確認できる方式であり、大規模環境や即時性が求められるシステムに適している。以上より、実運用環境では外部向けサービスには公開 CA を、内部システムにはプライベート CA を利用し、さらに CRL または OCSP による証明書失効管理を組み合わせることで、セキュリティと運用効率を両立した PKI 運用が実現できると考えられる。

2.1.4 私自身の視点から考えると

本演習を通して、PKI に基づくデータ暗号化基盤について、理論と実践の両面から理解を深めることができた。講義で学んだ公開鍵暗号や証明書の仕組みを、実際に Private CA の構築やサーバ証明書の発行といった作業を通して体験することで、PKI の具体的な動作や役割をより明確に理解することができた。特に、認証局（CA）による証明書発行のプロセスや証明書チェーンの検証の仕組みを実際に確認することで、PKI がインターネット上における通信の「信頼」を技術的に実現する重要な基盤であることを実感した。また、HTTPS 通信においてブラウザが証明書の正当性をどのように検証しているのかについても理解を深めることができた。さらに、証明書警告が表示されるケースや、CA の秘密鍵が漏洩した場合の影響についてシナリオを考察することで、PKI における信頼モデルやリスク管理の重要性についても学ぶことができた。特に、CA の秘密

鍵は PKI の信頼性を支える最も重要な要素であり、その管理が不十分である場合、広範囲にわたるセキュリティリスクが発生する可能性があることを理解した。

2.1.5 Web サービス企業の視点

企業においては、Web サービスやオンライン取引などにおいて HTTPS 通信を利用し、PKI に基づく TLS 証明書を用いることで通信の安全性を確保している。HTTPS は、通信内容の暗号化だけでなく、サーバの正当性を確認する仕組みを提供するため、インターネット上で安全なサービスを提供するうえで重要な技術となっている。

例えば、backmarket. co. jp のようなオンラインサービスでは、認証局（CA）によって発行された TLS 証明書を利用し、Web サーバの正当性を利用者に証明している。実際に、Google Trust Services などの信頼された認証局によって発行された証明書が利用されており、ブラウザは証明書チェーンを検証することでサーバの信頼性を確認している。この仕組みにより、通信内容の暗号化が実現されるだけでなく、なりすまし攻撃や通信の盗聴といったセキュリティリスクを低減することができる。一方で、PKI の安全性は証明書の管理や秘密鍵の保護に大きく依存している。そのため、企業においては証明書の適切な管理や更新、秘密鍵の厳重な保護など、運用面でのセキュリティ対策も重要となる。また、万が一鍵漏洩などのセキュリティインシデントが発生した場合に備え、証明書失効の仕組みや多層的なセキュリティ対策を講じることが重要であると考えられる。

2.2 マルウェア解析手法演習

マルウェア解析にはさまざまな手法があり、大きく 静的解析 と 動的解析 に分類される。静的解析（Static Analysis）とは、マルウェアを実際に実行せずに、バイナリファイルの構造やコードを分析する手法である。ファイル内に含まれる文字列情報やバイナリ構造を調査することで、マルウェアの特徴や機能を把握することが可能である。

一方、動的解析（Dynamic Analysis）は、仮想環境などの安全な環境でマルウェアを実際に実行し、その挙動を観察する手法である。この方法により、ファイルシステムの変更やネットワーク通信など、実行時の動作を確認することができる。演習では、実際のマルウェアデータセットを用いた分析や特徴量の確認を行い、さらに機械学習を用

いた分類手法について学習した。これにより、マルウェアの検知や分析における基本的な考え方を理解することができた。

2.2.1 Binary Refinery を用いたバイナリ解析

演習では、バイナリ解析ツールである Binary Refinery を用いて、バイナリデータの解析方法を理解することを目的とする。特に、エンコードされたデータの構造を確認し、ツールを利用してデコードすることで、元のデータ内容を読み取る手法について学習する。まず、サンプルのバイナリデータを Binary Refinery に入力し、データ構造の確認を行った。続いて、ツールに備わっている各種デコード機能を利用し、難読化またはエンコードされたデータの解析を行った。

例えば、emit コマンドを利用することで、16 進数表現、URL エンコード、Base64 などの形式で表現されたデータをデコードすることができる。以下に実行例を示す。

1. `$ emit h:507974686f6e`

Python

> この例では、16 進数データ 507974686f6e をデコードすることで、文字列 Python が得られる。

2. `$ emit q:%E5%AE%9F%E8%B7%B5%E3%81%99%E3%82%8B`

実践する

> この例では、URL エンコードされたデータをデコードすることで、日本語文字列「実践する」を取得することができる。

3. `$ emit b64:44OQ44Kk44OK44Oq6Kej5p6Q`

バイナリ解析

> この例では、Base64 エンコードされたデータをデコードすることで、文字列「バイナリ解析」を得ることができる。

このように、Binary Refinery ではさまざまなエンコード形式のデータを簡単に変換し、内容を確認することが可能である。

2.2.2 機械学習を用いた解析

機械学習を用いたマルウェア解析は、正規のバイナリデータおよびマルウェアデータを学習し、未知のマルウェアやその亜種を含むファイルを分類する手法である。本演習では、Windows の PE 形式のバイナリファイルを対象として、マルウェア検知モデルの構築および評価を行った。使用したマルウェアデータセットは、Prateek Lalwani 氏によって公開されているものである。このデータセットには、Windows 環境で実行される実行ファイルおよびライブラリファイル（.exe および.dll）から得られた正規ソフトウェアのバイナリデータ 41,323 件と、マルウェア共有プラットフォームである VirusShare から取得されたマルウェア検体 96,724 件の特徴量が含まれている。

これらのデータは、PE ファイルのヘッダから抽出された属性と値を CSV 形式で保存したものであり、マルウェアの特徴抽出および機械学習モデルの学習データとして利用した。さらに、これらのデータセットを組み合わせることで、正規ファイルとマルウェアの違いを学習させ、マルウェア検知モデルの性能を評価した。

2.2.3 探索的データ解析（EDA）

マルウェア検知モデルの構築前に、正規ソフトウェアおよびマルウェアの特徴量を分析するため、探索的データ解析（Exploratory Data Analysis : EDA）を実施した。EDA は、データの特徴を理解し、異常値の有無やデータの分布を確認するための分析手法である。EDA を行うことにより、データの傾向や関係性を把握し、その後の機械学習モデルの構築やデータ前処理の方針を決定することができる。

分析では、データの読み込みや整理、集計処理に Pandas ライブラリ を使用し、データの基本統計量の確認や欠損値の確認を行った。また、Matplotlib を用いてデータの分布や傾向をグラフとして可視化し、データの理解を深めた。これにより、データ全体の構造を把握することができ、後続の分析や機械学習モデルの構築に向けた基礎情報を得ることができた。

		Name	md5	Machine	...	LoadConfigurationSize	VersionInformationSize	legitimate
0		memtest.exe	631ea355665f28d4707448e442fbf5b8	332	...	0	16	1
1		ose.exe	9d10f99a6712e28f8acd5641e3a7ea6b	332	...	72	18	1
2		setup.exe	4d92f518527353c0db88a70fddcf390	332	...	72	18	1
3		DW20.EXE	a41e524f8d45f0074fd07805ff0c9b12	332	...	72	18	1
4		dwtrig20.exe	c87e561258f2f8650cef999bf643a731	332	...	72	18	1
...		...	...	...	...	...	...	...
138042	VirusShare_8e292b418568d6e7b87f2a32aee7074b	8e292b418568d6e7b87f2a32aee7074b	332	...	72	0	0	
138043	VirusShare_260d9e2258aed4c8a3bbd703ec895822	260d9e2258aed4c8a3bbd703ec895822	332	...	0	15	0	
138044	VirusShare_8d088a51b7d225c9f5d11d239791ec3f	8d088a51b7d225c9f5d11d239791ec3f	332	...	72	14	0	
138045	VirusShare_4286dccf67ca220fe67635388229a9f3	4286dccf67ca220fe67635388229a9f3	332	...	0	0	0	
138046	VirusShare_d7648eae45f09b3adb75127f43be6d11	d7648eae45f09b3adb75127f43be6d11	332	...	72	0	0	

[138047 rows x 57 columns]

図 3 : Pandas による CSV データの表示結果

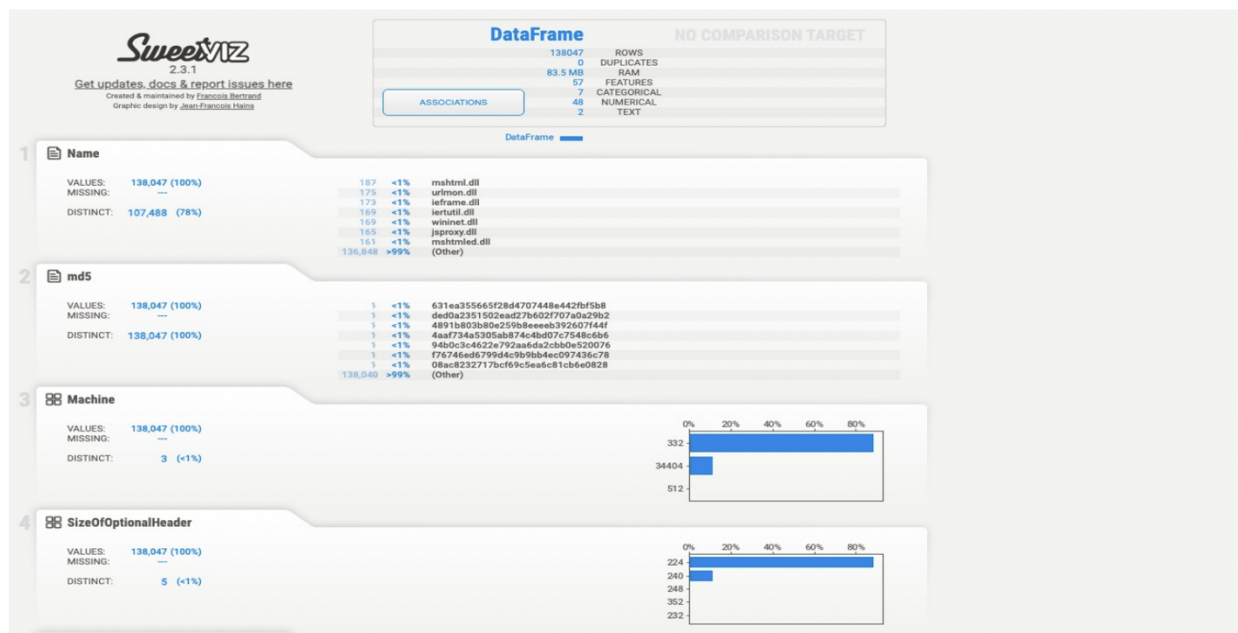


図 4 : Sweetviz による MalwareDataset.csv の分析結果

データの特徴を理解するために、特徴量と目的変数（legitimate）の関係性を可視化して確認した。正規ファイルとマルウェアで特徴量の分布に違いがあるかを視覚的に確認することができる。特定の特徴量がマルウェア検知に有効である可能性を事前に把握することができる。機械学習モデルの特徴量選択やデータ理解に役立つ。ここでは、57 個ある特徴量のうちの一つである VersionInformationSize と、ファイルが正規かマルウェアかを示す目的変数 legitimate との関係をヒストグラムで表した。

Feature: SizeOfUninitializedData	Importance: 0.20134
Feature: Machine	Importance: 0.12239
Feature: Characteristics	Importance: 0.11797
Feature: SizeOfInitializedData	Importance: 0.10288
Feature: MajorLinkerVersion	Importance: 0.07446
Feature: SizeOfCode	Importance: 0.06810
Feature: SectionAlignment	Importance: 0.06664
Feature: ImageBase	Importance: 0.05752
Feature: BaseOfCode	Importance: 0.05308
Feature: BaseOfData	Importance: 0.04470
Feature: MinorLinkerVersion	Importance: 0.03135
Feature: SizeOfOptionalHeader	Importance: 0.03100
Feature: AddressOfEntryPoint	Importance: 0.02857

図 5: 機械学習アルゴリズムによる特徴量の重要度

図 4 は、機械学習アルゴリズムを用いて算出した各特徴量の重要度（Feature Importance）を示したものである。特徴量の重要度とは、モデルがマルウェアと正規バイナリを分類する際に、各特徴量がどの程度分類結果に影響を与えるかを数値で表した指標である。結果を見ると、SizeOfUninitializedData が最も高い重要度（0.20134）を示している。SizeOfUninitializedData は、PE ファイルにおいて初期化されていないデータ領域（BSS セクション）のサイズを表す特徴量である。この値はプログラムの構造やメモリ使用方法に関係しており、マルウェアと正規プログラムの間で違いが現れる可能性がある。また、Machine は対象となる実行ファイルの CPU アーキテクチャ（例：x86, x64 など）を示す特徴量であり、Characteristics は PE ヘッダに含まれるファイルの属性情報（実行可能かどうか、DLL であるかなど）を示す特徴量である。これらの特徴量も比較的高い重要度を示している。

2.2.4 3つの機械学習モデルによる検出器の訓練結果

演習では、マルウェア検知モデルを構築するために、勾配ブースティング（Gradient Boosting）、ランダムフォレスト（Random Forest）、AdaBoost の3つの機械学習アルゴリズムを使用した。

モデル	Accuracy
勾配ブースティング（Gradient Boosting）	99.29 %
ランダムフォレスト（Random Forest）	99.30 %
AdaBoost	95.36 %

表 1：3つの機械学習モデルの分類精度の比較

表 1 より、ランダムフォレストモデルが最も高い分類精度（99.30%）を示し、次いで勾配ブースティング（99.29%）がほぼ同程度の高い性能を示した。一方で、AdaBoost は 95.36% となり、他の 2 つのモデルと比較するとやや低い結果となった。以上の結果から、アンサンブル学習アルゴリズムの中でも、ランダムフォレストおよび勾配ブースティングはマルウェア検知において非常に高い性能を示すことが確認された。

2.2.5 機械学習によるマルウェア分類の課題

機械学習を用いたマルウェア分類における課題を述べる。

- 実運用での主な利用場面

大規模ネットワーク環境におけるリアルタイム検知や、SOC におけるアラートの一次トリアージなど、自動化が求められる場面で利用される。

- 攻撃者による回避・対抗手法

攻撃者は、学習データに悪影響を与えるデータ汚染（データポイズニング）や、モデルの判断基準を推測した上で特徴を回避する手法を用いる可能性がある。

- セキュリティ対策としての限界

機械学習モデルは、学習データの質や量に大きく依存し、攻撃手法の変化による概念ドリフトへの継続的な対応が必要となる。また、検知結果の理由を明確に説明することが難しいという課題もある。

2.2.6 マルウェア解析手法の組み合わせに関する検討

近年のマルウェアは、難読化、環境検知、ファイルレス化、短時間での亜種生成など高度な検知回避技術を用いており、単一の解析手法では十分な検知・防御が困難になっている。本演習の中で、セキュリティ対策・攻撃検知の実用性を想定した観点から、静的解析・動的解析・機械学習を用いた解析をどのように組み合わせれば有効な防御になるかを検討した。実際の組織におけるセキュリティ対策を想定し、複数のマルウェア解析手法を組み合わせた統合アーキテクチャを設計した。

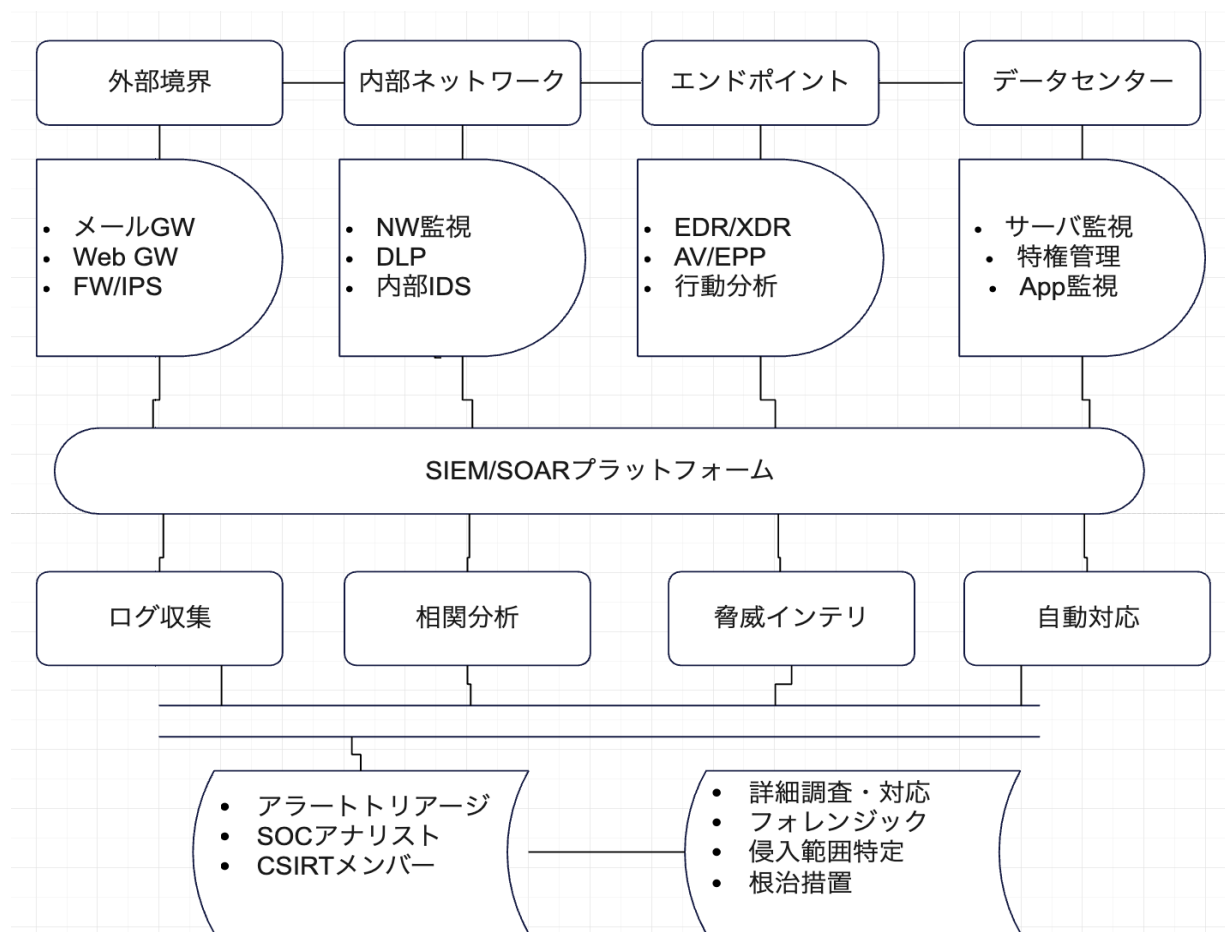


図 5: 統合セキュリティ監視アーキテクチャ

サイバーセキュリティは「完璧」を目指すものではなく、「継続的改善」を実践するものである。脅威は日々進化し、完全な防御は不可能である。しかし、本レポートで提案した多層防御アーキテクチャは、組織が現実的なリソースで実現可能な、効果的なアプローチの一つであるかなと考えて書いていました。重要なのは、技術の導入ではなく、

組織全体のセキュリティ文化の醸成である。経営層から現場まで、全員がセキュリティの重要性を理解し、日々の業務の中で実践する。それが、最強の防御となる。

2.2.7 私自身の視点から考えると

これまでセキュリティについては、主に講義を通して理論的な内容を中心に学んできた。しかし、本演習では実際にツールを使用しながら分析やネットワーク設計を行うことで、セキュリティ技術をより実践的に理解することができた。特に、実際の環境を想定した演習を通して、理論だけでは得られない経験を積むことができたと感じている。また、探索的データ解析（EDA）の演習では、データの分布や特徴を可視化しながら分析を進める過程が非常に興味深かった。データの特徴を理解し、そこから仮説を立てて検証するという流れを実際に体験することで、データ分析の重要性を実感することができた。さらに、マルウェア解析の演習を通して、マルウェアの構造や攻撃の仕組み、そしてそれを検知するための方法について理解を深めることができた。機械学習を用いたマルウェア検知の手法についても学ぶことができ、セキュリティ分野におけるデータ分析の有効性を強く感じた。

今回の演習を通して、セキュリティに関する理論だけでなく、実践的なスキルや分析の考え方を身につけることができた。

2.2.8 企業におけるマルウェア対策（初期分析）

企業の情報システムを安全に運用するためには、マルウェアをできるだけ早い段階で検知することが重要である。そのため、多くの企業ではシステム内で検出された疑わしいファイルに対して初期分析（Initial Analysis）を実施している。まず、疑わしいファイルのハッシュ値（MD5 や SHA256 など）を計算し、既知のマルウェアのデータベースと照合することで、既知のマルウェアであるかどうかを確認する。また、ファイルの構造や特徴量（ヘッダ情報、セクションサイズ、エントリーポイントなど）を分析し、正規ファイルと比較することで不審な点がないかを確認する。

さらに近年では、機械学習（Machine Learning）を用いたマルウェア検知技術も広く利用されている。機械学習モデルはファイルのさまざまな特徴量を分析し、そのファイ

ルがマルウェアである可能性を分類することができる。この方法は、従来のシグネチャベースの検知では発見が難しい未知のマルウェアを検出する場合にも有効である。

もしファイルがマルウェアである可能性が高いと判断された場合、感染拡大を防ぐためにファイルの隔離（quarantine）やネットワーク監視（network monitoring）などの対策を行う。また、必要に応じてシステム全体の調査を行い、被害の拡大を防止する。このような多層的な対策により、企業はマルウェアによるセキュリティリスクを低減している。

2.3 インシデントレスポンス演習

インシデントレスポンス演習では、ネットワークのアクセス制御の設計や、セキュリティインシデントのシナリオにおいて原因の分析や対策を検討した。

2.3.1 ネットワーク設計演習

最初の課題では、企業内ネットワークの安全性を高めるために、社内ネットワークの構成を設計し、ファイアウォールでのアクセス制御方式を検討した。図〇に示したテレワーク対応ネットワーク構成において、事務ネットワーク（事務 NW）と開発ネットワーク（開発 NW）を分離するためのアクセス制御リストを設計した。

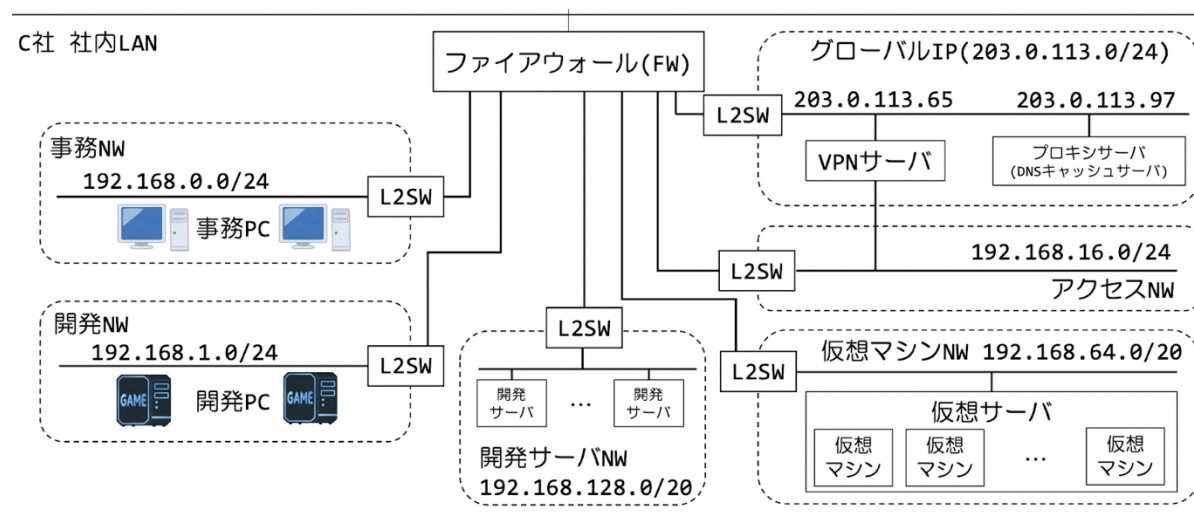


図 6:テレワーク対応ネットワーク構成

ACL 番号	送信元	宛先	プロトコル・ サービス	動作	備考
1	any	203.0.113.65	VPN (SSTP など)	許可	インターネット →VPN サーバ
2	203.0.113.97	any	HTTP(80), HTTPS(443), DNS	許可	プロキシ→インター ネット
3	192.168.16.0/24	192.168.64.0/24,	VDI	許可	VDI (仮想デスクト ップ) 接続 VPN サ ーバ→仮想サーバ NW (アクセス NW 経由)
4	192.168.0.0/23	203.0.113.97	HTTP / HTTPS	許可	事務 NW / 開発 NW →プロキシサーバ
5	192.168.64.0/23	203.0.113.97	HTTP / HTTPS	許可	仮想マシン NW → プロキシサーバ
6	192.168.10.24	192.168.128.0/24	HTTPS(443), SSH(22)	許可	開発 NW → 開発サ ーバ NW
7	192.168.5.0/24	192.168.128.0/24	HTTPS(443), SSH(22)	許可	開発用仮想サーバ → 開発サーバ NW
8	any	any	any	拒否	どの ACL にも一致 しない

表 2：テレワーク業務対応の FW のアクセス制御リスト

- この ACL 一覧は、ネットワーク上のアクセス制御を明確にするために作成したものです。
- 許可ルール (許可) は特定の通信を通すための設定で、例えば VPN やプロキシ、開発用サーバへのアクセスを管理しています。
- 拒否ルール (拒否) は、上記のいずれにも該当しない通信をブロックするための「デフォルトの安全策」です。
- これにより、不要なアクセスや不正アクセスからネットワークを守ることができます。

2.3.2 Web サイトからの情報流出インシデント

2つめの課題では、自動車販売代理店における Web サイトに不具合があり、情報流出したセキュリティインシデントにおいて、会社として取るべき行動、情報流出した原因を検討した。システムの構成や運用方法を確認し、どの部分にセキュリティ上のリスクが存在するのかを分析した。

2.3.3 企業におけるランサムウェア感染インシデント

三つ目の課題では、企業におけるランサムウェア感染インシデントへの対策について検討した。まず、認証強化の観点から、特権 ID「admin」のパスワードを推測困難な複雑なものへ変更するとともに、多要素認証（MFA）を導入することで、パスワードのみを用いた不正ログインを防止する。

次に、アクセスルールの変更として、VPN 経由で PC-P へ接続できる送信元 IP アドレスを P 社の業務端末のみに限定するアクセス制御リスト（ACL）を設定する。これにより、不審な外部 IP アドレスからの接続試行を遮断することが可能となる。

また、ログイン試行回数の制限（アカウントロックアウトポリシー）を設定し、一定回数以上の認証失敗が発生した場合には自動的にアカウントをロックする仕組みを導入することで、ブルートフォース攻撃への耐性を高めることができる。

さらに、特権 ID の利用を必要最低限に制限し、通常業務では一般権限のアカウントを使用する運用ルールを設けることが望ましい。以上のように、提示されたシステム構成およびインシデントの内容を踏まえ、システムに存在するセキュリティ上の課題を整理し、それに対する対策案を検討した 6。

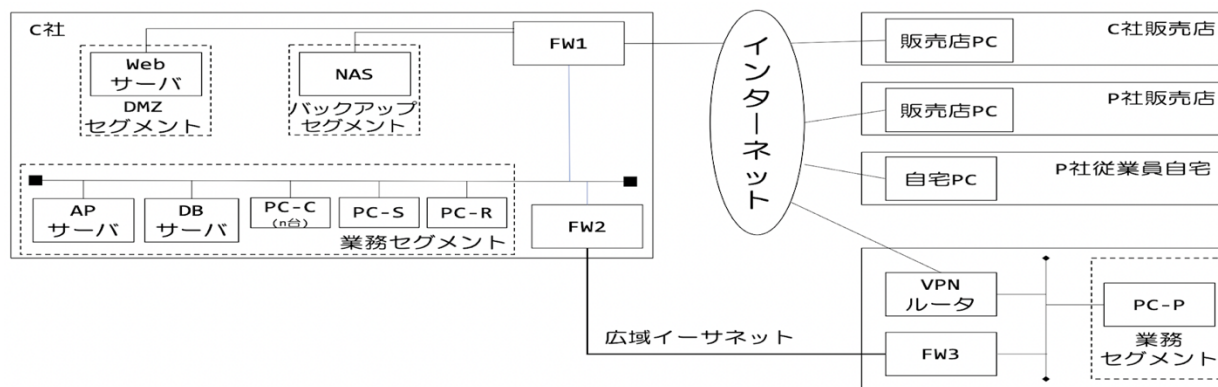


図 6: C 社および P 社のネットワーク構成

2.3.4 私自身の視点から考えると

インシデントが発生した場合には、まず状況を正確に把握し、被害の拡大を防ぐために迅速な対応を行うことが重要であることを理解した。また、インシデント対応では技術的な対策だけでなく、関係部署への迅速な報告や情報共有も重要であると感じた。適切な情報共有が行われることで、組織全体として迅速かつ効果的に対応することが可能になると考えられる。さらに、今回の演習を通して、インシデント対応には事前の準備や対応手順の整備が重要であることを実感した。実際のシステム運用では、インシデントが発生した際に迅速に対応できるよう、日頃から対策や体制を整えておく必要があると感じた。このような経験を通して、セキュリティ対策は技術面だけでなく、組織的な対応や運用面も含めて総合的に考えることが重要であると理解することができた。

2.3.5 企業の視点

企業においては、インシデントが発生した場合に被害を最小限に抑えるため、あらかじめ対応体制を整備しておくことが重要である。インシデントは突然発生する可能性があるため、迅速かつ適切に対応できるよう、日頃からセキュリティ対策や運用体制を整えておく必要がある。

特に、Web サーバのログ管理やアクセス監視を継続的に行うことで、不正アクセスや異常な通信を早期に検知することが可能になる。アクセスログやシステムログを適切に取得・分析することで、インシデントの兆候を早期に発見し、被害の拡大を防ぐことができる。また、Web アプリケーションに対しては、SQL インジェクションなどの脆弱性を事前に防ぐための対策を実装することが重要である。例えば、プレースホルダ

（Prepared Statement）の利用や入力値の検証を行うことで、不正なデータベース操作を防止できる。さらに、インシデントが発生した場合には、関係部署への迅速な報告や情報共有が不可欠である。組織内で明確な対応プロセスを整備しておくことで、インシデント発生時の混乱を防ぎ、迅速かつ適切な対応が可能になる。

企業は、このような技術的対策と組織的対策の両方を組み合わせることで、より効果的なセキュリティ対策を実現できる。

3. 実践インターンシップ

本章では、九州経済連合会(以下、九経連)が実施している ICT 人材育成事業（以下、実践インターン）に参加し、取り組んだ内容を報告する。

3.1 実践インターンシップテーマ

実践インターンシップは、公益財団法人 九州先端科学技術研究所(ISIT)にて、約 1 か月間実施した。ISIT をインターンシップ先として選択した理由は、オープンデータを活用した研究・開発を行っている点に強い関心を持ったためである。また、日本の研究機関における実務経験を通じて、技術的な基礎知識や実践的なスキルだけでなく、組織文化や職場環境についても学ぶことを目的として、実践インターンシップに参加した。

インターンシップ期間中、ISIT が運営する複数の Web ページに触れる機会があり、これらの Web システムが多くの利用者に情報を提供する重要な役割を担っていた。私自身が情報セキュリティ分野に関心を持ち、特に Web セキュリティについて基礎的な知識を学んできたことから、ISIT 側との相談により、インターンシップで取り組むテーマとして「Cybersecurity Web Page Best Practices」を選択した。

本報告書では、インターンシップを通じて学んだ Web セキュリティに関する知識を整理し、Web ページを安全に運用するためのプラクティスについて考察する。

3.2 Overview of Web Security Threats

近年、Web アプリケーションやインターネットに接続されたシステムを狙うサイバー攻撃は急速に増加している。具体的な統計からもその深刻さが確認されている。まず、2024 年に観測された Web アプリケーションへの攻撃総数は 12 億件を超え、1 日平均約 330 万回に達したと報告されている。前年同期比では 154%の増加であり、攻撃の

頻度と規模が拡大している。さらに 2025 年第 1 四半期の統計では、3 か月間で約 3 億 6,700 万件のサイバー攻撃が検知され、1 日に最大約 692 万件、1 秒あたり約 80 回もの攻撃が発生している。前年同期と比べても約 3 倍の増加傾向が観測される。攻撃の種類としては、ボットネットによる大量アクセスや DDoS、脆弱性スキャン、SQL インジェクションやクロスサイトスクリプティングなどの Web 攻撃が依然として多い。また、ランサムウェア攻撃は 2025 年後半にかけて前年比約 60%増加しており、生成 AI を悪用した情報漏えいリスクも指摘されている。このように、Web セキュリティ脅威は単なる増加傾向にとどまらず、攻撃の精巧化と自動化が進んでいる点が特徴であり、適切な防御対策の継続的な実施が強く求められている。

3.3 インターンシップでの取り組み

私はインターンシップ期間中、2 つのトピックに取り組んだ。

- ネットワークセキュリティ分析ツールの開発
- Web アプリケーションに対する攻撃からの基本的な防御方法
 - テスト用の Web サイト構築
 - DVWA における攻撃パターン検証

3.3.1 ネットワークセキュリティ分析ツールの開発

ネットワークセキュリティ分析ツールの作成に取り組みました。この活動では、ログ解析を通じてネットワーク通信の挙動を確認し、不審なアクセスや異常の検知について学びました。

インターンシップ期間中、実際に稼働している Web サーバーのアクセスログ分析に取り組みました。はじめに、1 日分のサーバーログを PowerShell を用いて手作業で分析しましたが、ログの量が非常に多く、HTTP ステータスコード (404, 400, 499 など) や不審なリクエストを一つ一つ確認する作業には、長時間を要しました(図○)。この経験を通じて、ログ分析を効率化し、継続的に不正アクセスや異常なトラフィックを検知するためには、自動化された仕組みが不可欠であると考えた。以下の点に着目し、実践的な視点から Web セキュリティへの理解を深めることを目的とした。

- 不正アクセスの兆候をログからどのように検知できるか

- アクセス制御によって被害をどのように低減できるか

```

geoserver/web/ HTTP/1.1" 404 132717 "
6.71 Safari/537.36 SE 2.X MetaSr 1.0"
sit.or.jp_20250805.log:2:Aug 5 00:16
.git/config HTTP/1.1" 404 132717 "-"
afari/537.36"
sit.or.jp_20250805.log:4:Aug 5 00:51
version HTTP/1.1" 499 0 "-" "Mozilla/
5.0 (compatible; Thinkbot/0.5.8; +In

jp_20250805.log:4:Aug 5
HTTP/1.1" 499 0 "-" "Mo
4.1 Mobile/15E148 Safari/
jp_20250805.log:12:Aug

og:743:Aug 5 12:52:55 m089.is
/1.1" 400 255 "-" "Mozilla/5.0
og:841:Aug 5 13:31:01 m089.is
pbpf HTTP/1.1" 499 0 "https://
5_7) AppleWebKit/537.36 (KHTML
og:842:Aug 5 13:31:01 m089.is
pbpf HTTP/1.1" 499 0 "https://

Log:3524:Aug 5 20:49:03 m089.isit.or
:443 HTTP/1.1" 400 157 "-" "-"
Log:3528:Aug 5 20:59:24 m089.isit.or
B%7B%20data.uploadedToLink HTTP/1.1"
5.0 (compatible; Thinkbot/0.5.8; +In

```

図 7: 実際に稼働しているサーバーのログ分析

ログ分析を自動化するために、ネットワークセキュリティ分析ツールであるサーバログ解析システム「Traffic Eye Log Analyzer」を開発した。Traffic Eye Log Analyzer は、サーバ管理者の負担軽減とセキュリティ向上を目的として、ログを自動で解析し、グラフで可視化することで、疑わしい IP や高負荷を迅速に特定し、管理者の作業時間を節約し、セキュリティを向上できる。

Traffic Eye Log Analyzer の特徴を以下に示す。

1.ログの読み込み・データ処理

Web サーバで生成される access.log, error.log を読み込み、以下の情報を解析し、アクセスの傾向やエラー発生状況を効率的に把握できる。

- IP アドレス
- リクエストタイプ (GET, POST など)
- リクエスト時刻
- HTTP ステータスコード (200, 404, 500 など)

2.統計情報の集計・可視化

解析したログデータを基に、以下の統計情報を算出する。下記の統計情報は、横棒グラフ、縦棒グラフ、円グラフ、折れ線グラフ を用いて可視化され、管理者が直感的にアクセス状況を把握できる。

- 総ユニーク IP アドレス数

- 最大リクエスト数を送信した IP アドレス
- 最もアクセスされた URL
- 日別・時間別・分別のトラフィック量

3.セキュリティ分析機能

ログ解析結果を基にしたセキュリティ分析から不正アクセスの早期発見や被害の未然防止を支援する。

- 短時間に繰り返しリクエストを送信する IP アドレスの特定
- 過剰なリクエストを行う IP アドレスに対するブロック提案
- ブルートフォース（Brute Force）攻撃などの兆候検出

図 8 に、開発した Traffic Eye Log Analyzer のログ解析結果画面を示す。ツールを用いて、特定の日における Web サーバのアクセスログを詳細に解析し、トラフィックの傾向を把握するとともに、高負荷を与えている IP アドレスや不審なアクセスを調査した。ログデータは、ISIT で運用しているサーバの access log / error log を用いた。

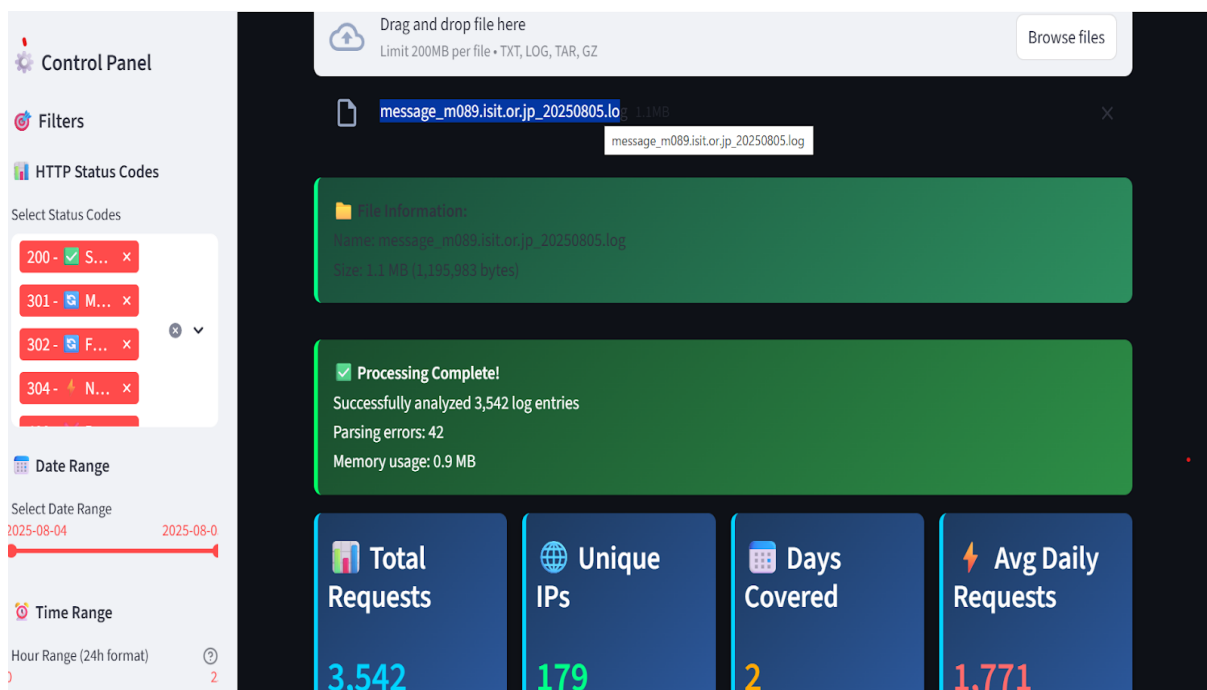


図 8: Traffic Eye Log Analyzer のログ解析結果画面

図 8 の画面上部では、対象となるログファイルを ドラッグ&ドロップ またはファイル選択によってアップロードすることができる。ログファイルの読み込み後、システムは自動的に解析処理を実行し、以下の結果が得られ、比較的軽量なリソース消費で、大量のログデータを処理できることを確認した。

- 解析対象ログ件数：3,542 件
- パースエラー数：42 件
- メモリ使用量：約 0.9MB

図 8 の画面下部には、アクセス統計情報の可視化としてログ解析によって得られた主要な統計情報をカード形式で表示している。これらの情報から、対象 Web サーバのアクセス規模やトラフィックの傾向を把握できる。

- Total Requests(解析対象期間における総リクエスト数): 3,542 件
- Unique Ips(アクセス元のユニーク IP アドレス数): 179 件
- Days Covered(ログが含む期間 (日数)): 2 日間
- Avg Daily Requests(1 日あたりの平均リクエスト数): 1,771 件

IP Address Analysis(IP アドレス分析)の目的は、IP アドレスの動きを監視・分析し、潜在的なセキュリティリスクを特定することである。単に IP アドレスを一覧化することではなく、その背後にあるユーザー行動、システム負荷、そして潜在的なセキュリティリスクを総合的に評価し、迅速に対応できるようにするためである。表○に、IP Address Analysis で表示している内容を示す。図○の左側のグラフは、Web サーバに最も多くアクセスした、または最も多くリクエストを送信した IP アドレスを一覧表示する。これにより、どのアドレス（または地域、ユーザー）がシステムに最も大きな負荷を与えているかを把握できる。単一の IP アドレスからのリクエストの最大数を示し、この数値が異常に高い場合は、DoS 攻撃あるいは DDoS 攻撃を目的とした大量のリクエストの可能性がある。また、ボットの活動として Web サイトの情報を収集（スクレイピング）や、脆弱性を探す自動ボットの可能性がある。Top 20 IP Addresses に、不審または見覚えのない海外の IP アドレスが多く含まれている場合、セキュリティチームは注意を払い、調査する必要がある。

分析したアクセスログでは、最も活動していた IP アドレスは、60.109.211.189 であった図 9。60.109.211.189 と 59.190.151.132 のアクセス数が非常に多く、通常ユーザではなく、ボットなど自動化されたアクセスの可能性が推測され、セキュリティの観点から不審な IP アドレスとして、詳細な調査が必要である。

内容	詳細
Top 20 IP Addresses	アクセスログ中のアクセス数が多い上位 20 件の IP アドレスを表示・カラーバーでアクセス数を表現（緑：多い，青／紫：少ない）
Total Unique Ips	アクセスログ中の異なる IP アドレスの総数
Most Active IP	アクセスログ中の最も活発な IP アドレス
Max Requests from Single IP	単一 IP からの最大リクエスト数 15,568 回

表 3：アクセスログにおける IP アクティビティの概要

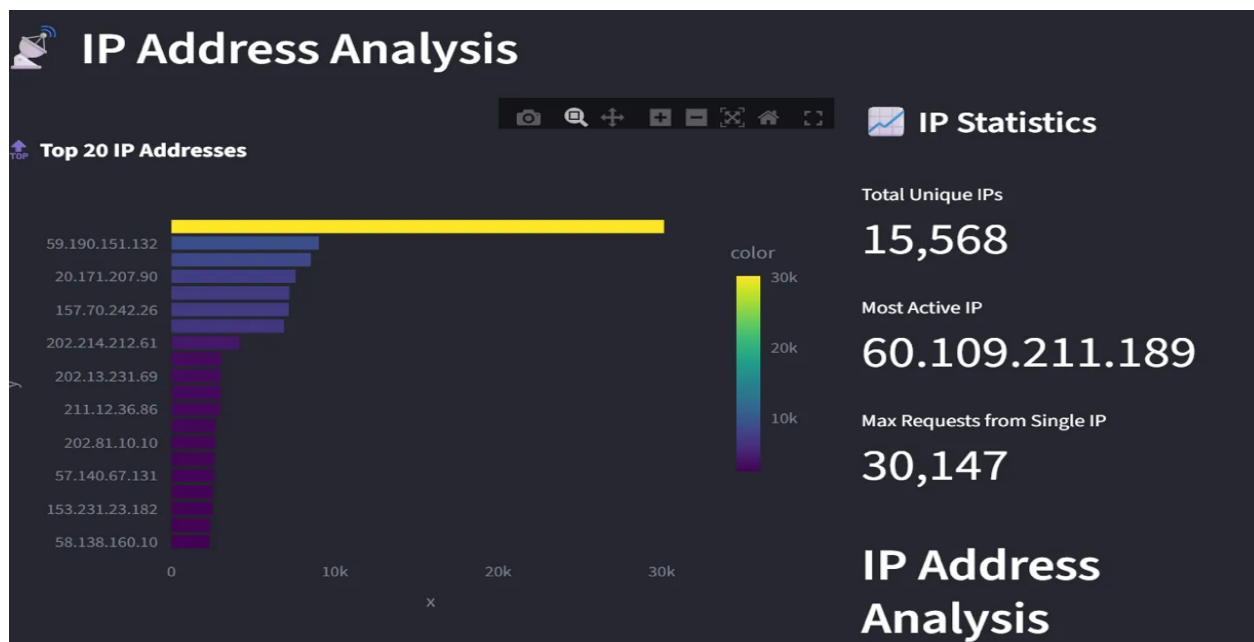


図 9:IP Address Analysis のログ解析結果画面

3 万を超えるアクセスがあった IP アドレス 60.109.211.189 について詳細に調査した。何をどうやって調査したのか、述べること。何を調べた結果なのか2枚の図を説明すること。

60.109.211.189 was not found in our database	
ISP	Japan Nation-wide Network of Softbank Corp.
Usage Type	Mobile ISP
ASN	Unknown
Hostname(s)	softbank060109211189.bbtec.net
Domain Name	bbtec.net
Country	 Japan
City	Saitama, Saitama

図 10: IP アドレス 60.109.211.189 について詳細に調査結果

IP Location	 Japan Tokyo Japan Nation-wide Network Of Softbank Corp.
ASN	 AS17676 GIGAINFRA SoftBank Corp., JP (registered Mar 26, 2001)
Resolve Host	softbank060109211189.bbtec.net
Whois Server	whois.apnic.net
IP Address	60.109.211.189

% Abuse contact for '60.96.0.0 - 60.127.255.255' is ' abuse@e.softbank.co.jp '	
inetnum:	60.96.0.0 - 60.127.255.255
netname:	BBTEC
descr:	Japan Nation-wide Network of Softbank Corp.
country:	JP
org:	ORG-SC4-AP
admin-c:	SA421-AP
tech-c:	SA421-AP
abuse-c:	AS2391-AP
status:	ALLOCATED PORTABLE
remarks:	-----
remarks:	To report network abuse, please contact mnt-irt
remarks:	For troubleshooting, please contact tech-c and admin-c
remarks:	Report invalid contact via www.apnic.net/invalidcontact
remarks:	-----
mnt-by:	APNIC-HM
mnt-lower:	MAINT-JP-BBTECH
mnt-routes:	MAINT-JP-BBTECH

図 11:IP アドレス 60.109.211.189 について詳細に調査結果 2

HTTP Status Code Analysis による分析の目的は、Web サーバの動作を監視・評価し、潜在的な問題を検出することである。HTTP Status Code Analysis では下記に示す状況を把握する。

- どのファイルやパスが最も負荷を受けているかを把握し、リソースの最適化やキャッシュ利用に活用する。
- ユーザがどの参照元から最も訪問しているかを把握し、マーケティング、SEO、トラフィック管理に活用する。
- Web サーバのリソース消費やネットワーク負荷を最適化し、ユーザ行動をより深く理解する。

表 4 に HTTP Status Code が持つ意味を示す。これらの HTTP Status Code をアクセスログから集計し、図 12 に示す画面のように表示する。

status code	意味	ログに記録される理由
200	OK	正常にページが表示されたリクエスト。ログとして記録され、ユーザの閲覧履歴の把握に利用できる。
304	Not Modified	ブラウザのキャッシュが利用された場合でも、アクセス履歴としてログに記録される。
302	Found (Moved Temporarily)	一時的な URL 転送が発生したことを記録し、リダイレクト状況を把握できる。
499	Client Closed Request	ユーザまたはクライアントが途中でリクエストを中断したことを示す。
404	Not Found	存在しないページへのアクセスを把握し、リンク切れ確認に利用できる。
500	Internal Server Error	プログラムやDBなどサーバ内部の問題を特定するためログに記録される。
403	Forbidden	権限のないアクセス試行として記録される。

status code	意味	ログに記録される理由
504	Gateway Timeout	上位サーバや API の応答遅延・障害を把握するために記録される。
301	Moved Permanently	URL 変更履歴を管理し, SEO(検索エンジン最適化)や転送設定確認に利用される。
502	Bad Gateway	プロキシやロードバランサーの障害を特定するため記録される。

表 4 : HTTP Status Code Analysis の概要

Dep

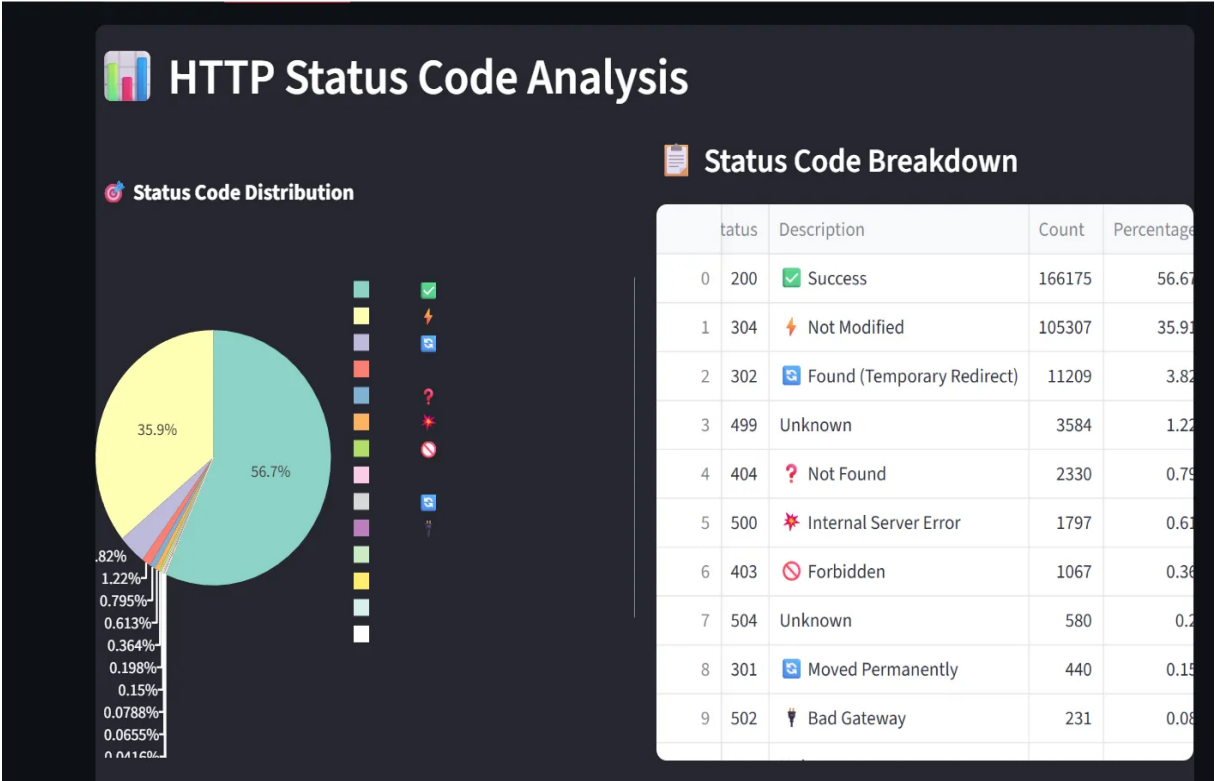


図 12: HTTP Status Code Analysis のログ解析結果画面

Traffic Source Analysis では、トラフィック流入元分析機能を提供する。Web サーバのアクセスログを基に、どの URL が多くアクセスされているか、どのページ（参照元）からアクセスが発生しているかを可視化した分析結果を示している。図○の左側の

グラフは、Most Requested URLs でアクセス数が多い上位 URL を示している。カラーバーはアクセス数の多さを表しており、黄色に近いほどアクセス数が多いことを示す。図 13 では、CSS、JavaScript、フォントファイルなどの静的リソース（/webassets/ 配下）へのアクセスが多い jquery.js や bootstrap.js など、Web ページ表示に必要なライブラリへのリクエストが集中していることが確認できる。これにより、本 Web サイトではページ表示時に多くの静的リソースが読み込まれていることが分かる。図 13 の右側の表は、Top Referrers を示しており、アクセスの参照元（Referrer）とその回数を表示する。ドメイン内のページからのアクセスが大半を占めているデータセットページ（/dataset/～）からの遷移が多く、利用者がデータ閲覧を目的としてサイトを利用していることが分かる。特定のページから数千回単位のアクセスが発生しており、人気コンテンツや頻繁に参照されるページの把握が可能である。

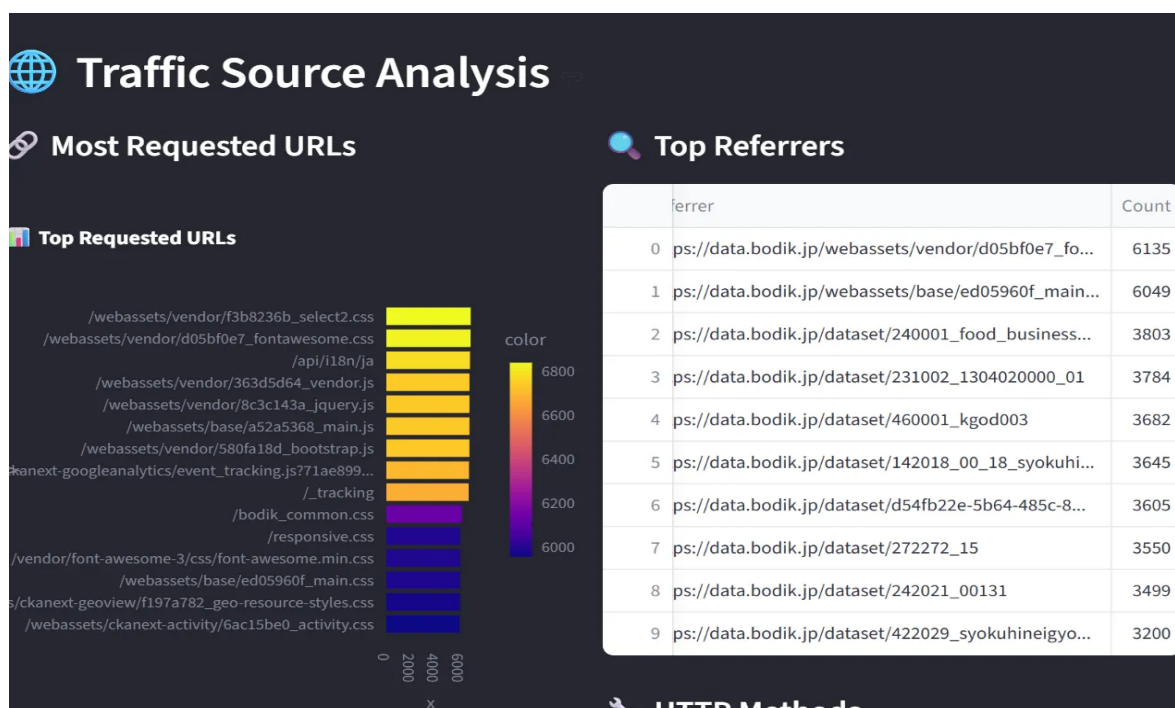


図 13: Traffic Source Analysis のログ解析結果画面

分析したアクセスログから、本サイトでは、Web ページの表示に必要な静的リソースへのアクセスが非常に多い内部ページ（データセットページ）からの遷移が中心であった。外部サイトからの不審な流入は少ない人気ページや高頻度アクセス URL を把握す

ることで、キャッシュ設定やアクセス制御の最適化に活用できる。セキュリティおよび運用面では、この分析結果から、アクセス集中箇所の把握によるサーバ負荷対策や、は異常なリクエストの検出に活用できる。

Advanced Analytics は、図 14 に示すように、Response Size Analysis を可視化することで、サーバから配信されるファイルのサイズを把握し、Web サイト管理者がシステム負荷や Web サイト速度などを理解できる。例えば、1MB 以上のファイルが多く配信されている場合、サーバリソースが多く消費されていることを示します。また、1KB～1MB のファイルが極端に多い場合、ページの読み込み速度が低下する可能性がある。この場合、画像サイズの縮小や CSS・JS ファイルの統合など、最適化の措置を講じて、Web サイトのアクセス速度への改善につなげる。0 バイトのレスポンス数が多い場合、キャッシュが適切に機能しており、サーバへの不要な負荷を防いでいることを示す。

サーバログを自動的に解析し、グラフにより可視化することで、疑わしい IP アドレスや高負荷の原因を迅速に特定できるシステムである。本システムを活用することで、管理者の作業時間を削減するとともに、Web サーバのセキュリティ向上に貢献することが期待される。

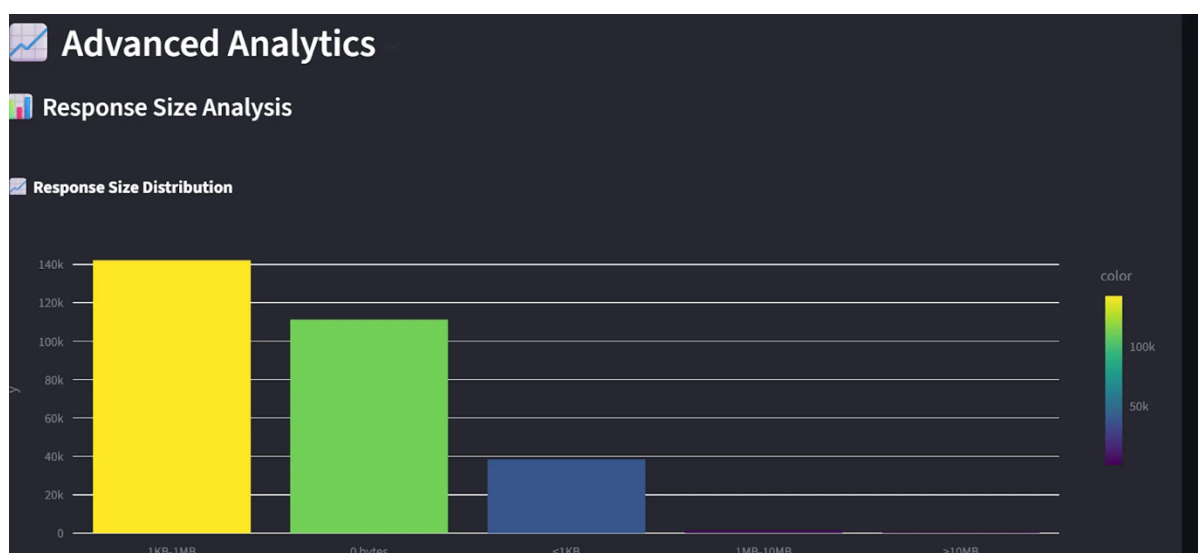


図 14:Advanced Analytics のログ解析結果画面

3.3.2 Web ページ上でのアクセス制御方法に関する調査

攻撃から Web サイトの守り方を学ぶために、Web アプリケーションを構築した。これにより、単なる理論的な学習に留まらず、実際の動作環境に近い形でセキュリティ上の課題を検証できる環境を整えた。自身で図 15 から図 16 に示す Web ページを Python (Flask) で作成した。開発環境として Ubuntu を使用し、ローカルサーバを起動して動作確認を行った。この Web ページでは、バックエンドにデータベースを用いて情報を蓄積できるようにしている。

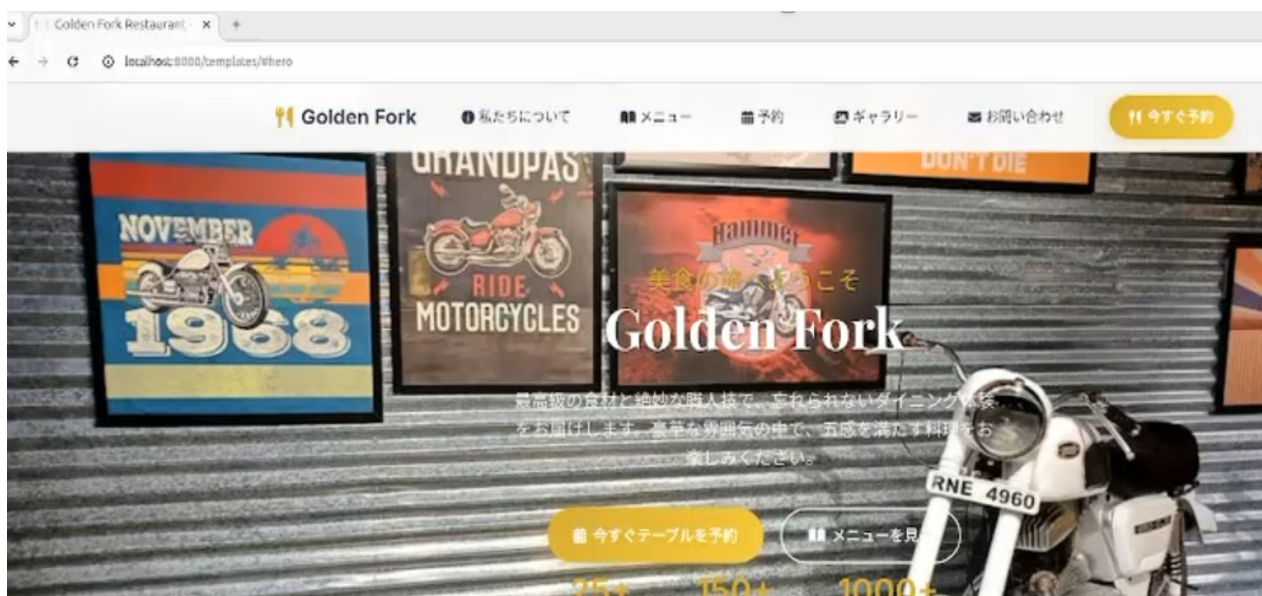


図 15: 作成した Web ページ (Golden Fork Restaurant のトップページ)



図 16: ウェブページをヘッダー2

本来であれば、Web セキュリティを学ぶためにゼロから脆弱性を含む Web アプリケーションを設計・開発することが望ましかったが、準備や実装に多くの時間を要する課題があった。そこで本インターンシップでは、Web セキュリティの学習および攻撃手法の理解を効率的に進めるため、意図的に脆弱性が組み込まれている学習用 Web アプリケーションである DVWA (Damn Vulnerable Web Application) (図〇)を用いて実験した。実際に、DVWA を用いてさまざまな攻撃パターンを検証し、それぞれの攻撃手法の仕組みや影響、対策の基本について理解を深めた。

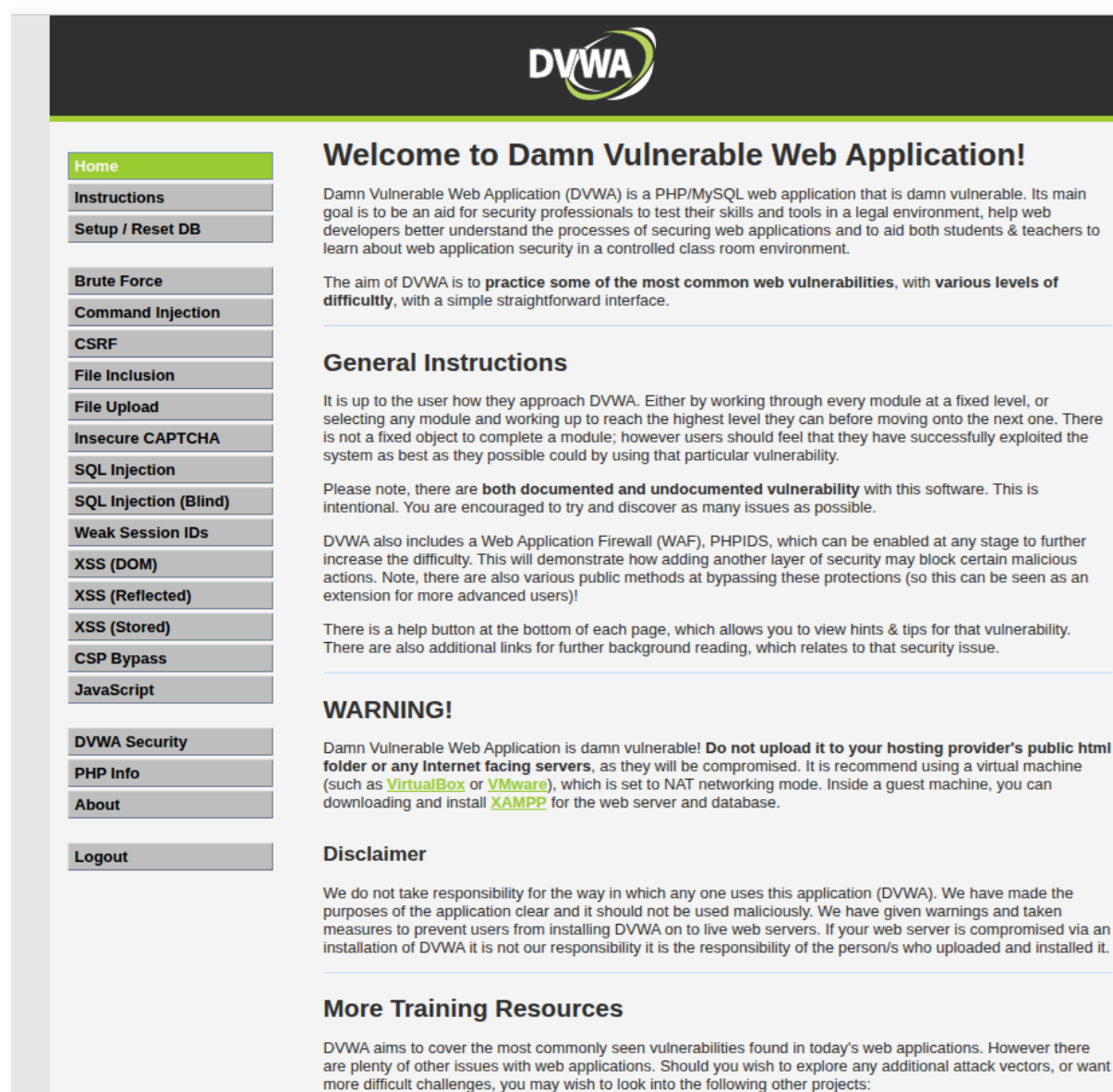


図 17: Damn Vulnerable Web Application の画面

検証(1): SQL インジェクション

SQL インジェクションは、Web アプリケーションがユーザの入力を検証せずに SQL クエリに直接組み込むと、攻撃者は自分の SQL コードを入力として送り、データベースに影響を与える。SQL クエリ "SELECT * FROM users WHERE username = 'ユーザ入力' AND password = 'パスワード入力';" に、ユーザからの入力を検証せずにそのままクエリに埋め込むことで SQL インジェクションが発生する。攻撃側が、図 17 の User ID フォームに文字列 ' OR '1'='1 を入力すると、'1'='1' と、SQL 文の WHERE 句が常に真となり、認証をバイパスできる。

DVWA

Vulnerability: SQL Injection

User ID:

ID: ' OR '1'='1
First name: admin
Surname: admin

ID: ' OR '1'='1
First name: Gordon
Surname: Brown

ID: ' OR '1'='1
First name: Hack
Surname: Me

ID: ' OR '1'='1
First name: Pablo
Surname: Picasso

ID: ' OR '1'='1
First name: Bob
Surname: Smith

More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout

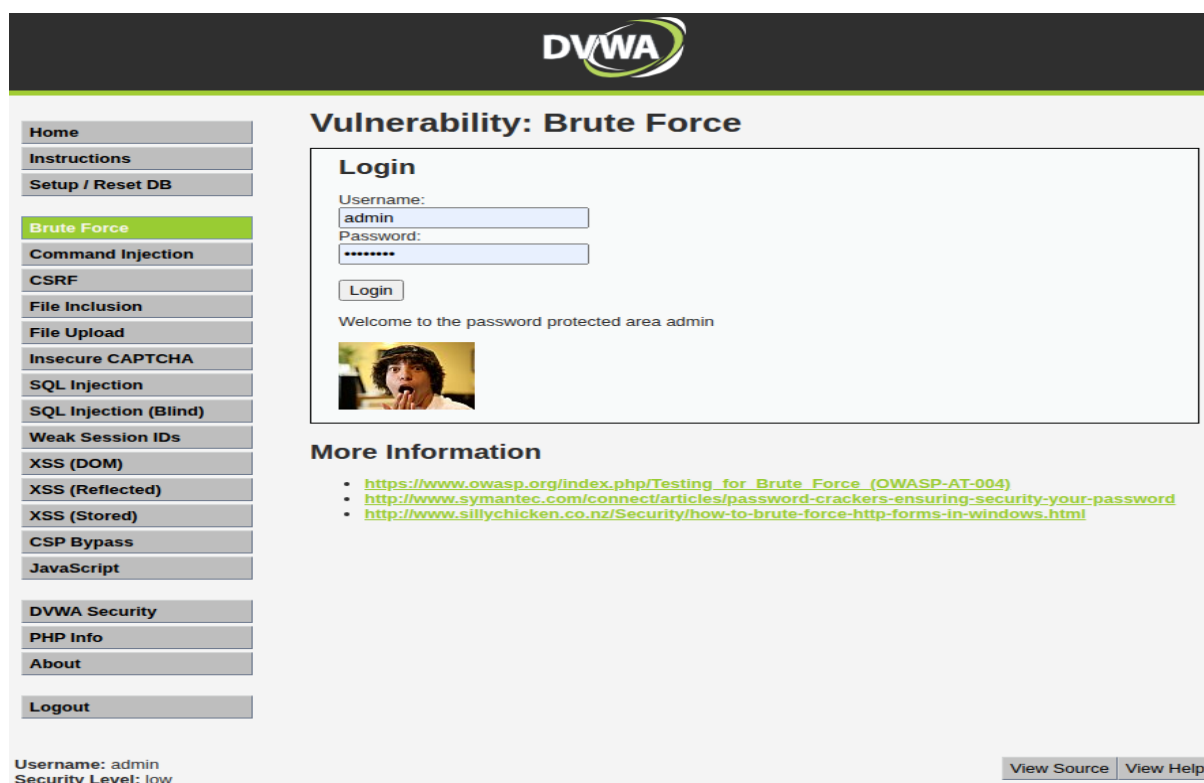
Username: admin
Security Level: low

図 17:DVWA の SQL Injection 画面

検証(2):ブルートフォース

ブルートフォース攻撃は、攻撃者がターゲット（ログイン画面や暗号化されたデータ）を可能なパスワードや鍵の組み合わせを順番に試行して、正しい組み合わせが見つかるまで繰り返す攻撃手法である。例えば、4桁の数字から構成されるパスワードであれば、0000, 0001, 0002, ..., 9999 と最大 10,000 通りを試せば必ず突破可能である。

この画面は、DVWA（Damn Vulnerable Web Application）におけるブルートフォース攻撃の演習画面である。ログインフォームにユーザー名（admin）とパスワードを入力する形式となっており、攻撃者がパスワードを総当たりで試行することを想定した脆弱な環境を示している。正しいパスワードが入力された場合、"Welcome to the password protected area admin" というメッセージが表示され、ログイン成功が確認できる。本画面は、ブルートフォース攻撃に対する防御策が施されていない状態を意図的に再現しており、アカウントロックや試行回数制限などのセキュリティ対策の重要性を学ぶために使用される。



DVWA

Vulnerability: Brute Force

Login

Username:

Password:

Welcome to the password protected area admin



More Information

- [https://www.owasp.org/index.php/Testing_for_Brute_Force_\(OWASP-AT-004\)](https://www.owasp.org/index.php/Testing_for_Brute_Force_(OWASP-AT-004))
- <http://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password>
- <http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html>

Username: admin
Security Level: low

[View Source](#) [View Help](#)

図 18:DVWA の SQL Injection 画面

3.3.3 Web Server Monitoring Dashboard の開発

CPU, ネットワーク, プロセス, システム情報を 個別に確認するのは手間がかかり, 時間も浪費する負荷や不審なネットワーク動作, 異常なプロセスを早期に検知するためサーバやシステムの状態を 一箇所から総合的に監視する必要があった. そこで, Web サーバのシステム全体のリソース(CPU, メモリ, ディスク, ネットワーク)を一目で把握できる Web Server Monitoring Dashboard を開発した. CPU, RAM, ディスク使用率を リアルタイムグラフ で可視化(図○, 図○)し, 時系列で負荷の変化を分析できる. ネットワーク使用状況, 送受信トラフィック, アクティブな IP を監視し, 急激なトラフィック増加や不審な接続を検知する(図 19).

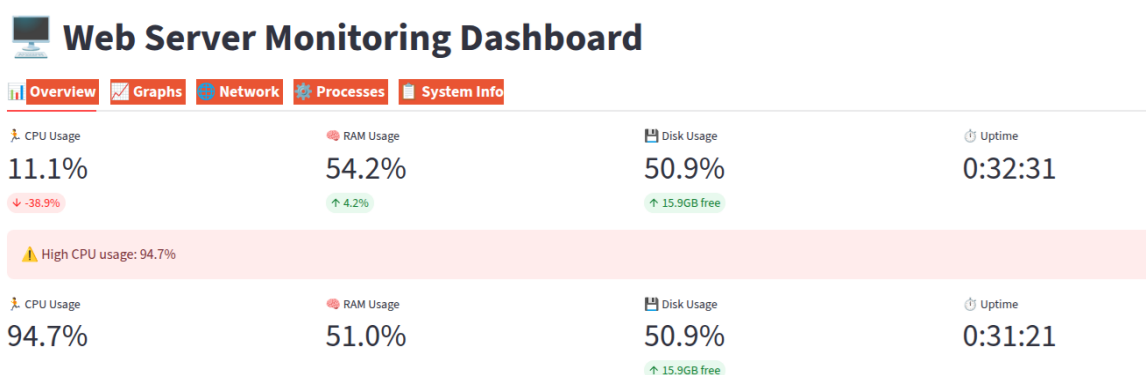


図 19: Web_Server_Dashboard のプログラムの画面

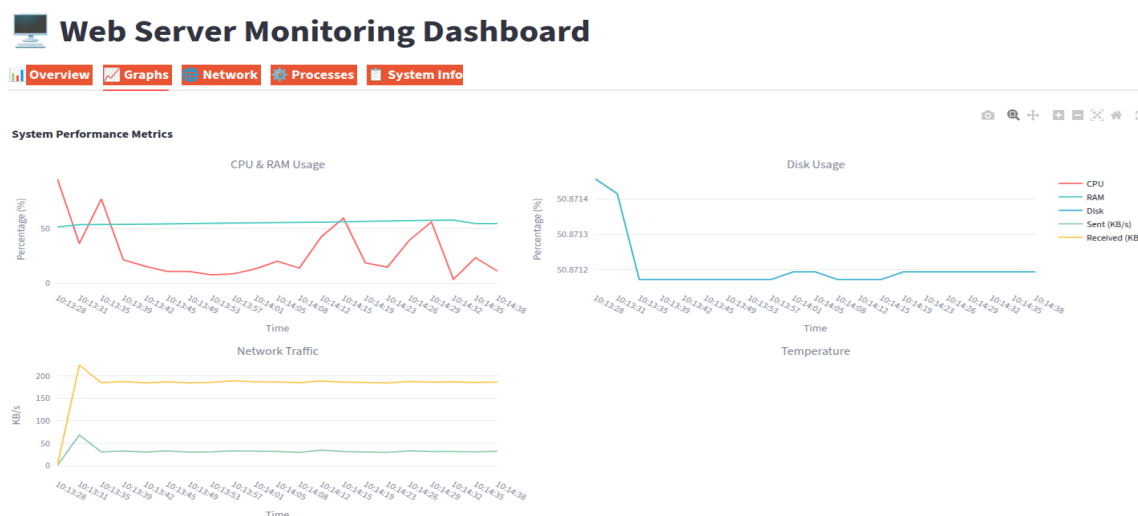


図 20: System Monitoring の画面

Web Server Monitoring Dashboard

 Overview  Graphs  Network  Processes  System Info

Website Monitoring

✓ <https://google.com>

Response Time

256ms

✓ <https://github.com>

Response Time

262ms

Network Interfaces

	Interface	Status	Speed
0	lo	Up	Unknown
1	enp0s3	Up	Unknown
2	docker0	Down	Unknown
3	br-1303a0bf3d7f	Up	10000 Mbps
4	vethc434832	Up	10000 Mbps
5	veth2dadf18	Up	10000 Mbps

図 20: Network monitoring の画面

Web Server Monitoring Dashboard では、すべての情報を 1 つのダッシュボードで確認できるため、統合監視が、可能となる。

- リアルタイム情報: 負荷の変化を即座に把握できる
- セキュリティ強化: 不審なネットワーク接続や異常プロセスを早期検出
- 使いやすいユーザインタフェース: 管理者や利用者に直感的でわかりやすい
- 拡張性: 他のサーバやサービスも追加して監視可能

3.4 インターンシップで学んだこと

インターンシップを通じて、Web 開発、サーバ監視、プログラミング、WBS およびデータベースの基礎に関する知識を体系的に学習した。特に、Web アプリケーションの構成やサーバの動作原理を理解した。また、DVWA (Damn Vulnerable Web Application) を用いた攻撃テストを実施し、SQL インジェクションや XSS などの代表的な脆弱性について、攻撃者視点と防御者視点の両面から理解を深めた。加えて、サーバーログの確認・分析することで、不審な挙動や攻撃の痕跡を把握する実践的な経験をした。

さらに、問題が発生した際には、エラーメッセージやログ情報を手がかりに原因を調査し、ドキュメントや技術情報を参照しながら自ら解決する能力を養った。これにより、単に指示された作業だけでなく、実運用を想定したトラブルシューティング能力や主体的に課題へ取り組む姿勢を身につけることができた。

また、業務を円滑に進めるためのソフトスキルの重要性を実感した。特に、ホウレンソウ（報告・連絡・相談）を意識して行動することで、状況共有の遅れによる問題を防ぎ、周囲と協力しながら作業を進める習慣が身についた。この他にも、分かりやすく簡潔に伝える力が向上した。専門的な内容であっても、要点を整理し、相手に伝わりやすい形で説明することを心がけることで、コミュニケーションの質を高めることができた。さらに、期限内にタスクをやり遂げる意識が向上した。任された作業に対して責任を持ち、作業内容を計画的に整理しながら進めることで、納期を意識した行動が取れるようになった。

加えて、課題に直面した際の改善提案力も向上した。問題が発生した場合には、自ら調査を行い、原因を分析した上で解決策を検討し、改善案として提案する姿勢を身につけることができた。

4. おわりに

セキュリティ実践演習第一を通して、データ分析、マルウェア解析、インシデントレスポンス、公開鍵認証基盤（PKI）について、理論だけでなく実践的に学ぶことができた。各演習では実際のデータや事例をもとに課題に取り組むことで、情報セキュリティに関する知識をより具体的に理解することができた。

また、自分自身で分析や対応方法を考える過程を通して、問題解決の考え方や分析力の重要性を実感した。さらに、今回の演習を通して、今後どのような技術や知識を身につける必要があるのか、またどのような能力を強化すべきかについても考えることができた。

セキュリティ実践演習第一では、限られた時間の中で課題に取り組む必要があったが、その過程で技術的な理解を深めるとともに、実践的な経験を得ることができたと感じている。

実践インターンシップでは、Traffic Eye を用いたログ分析、Web アプリケーションの構築、DVWA を用いた脆弱性攻撃の体験という活動を通して、セキュリティ運用に関する理解を深めることができた。実際の運用を想定した環境で学習することで、ログから異常を読み取る重要性や、Web アプリケーションに潜む脆弱性の危険性を実感した。

また、攻撃者の視点と防御側の視点の両方を体験することで、セキュリティ対策は単なる技術導入だけでなく、継続的な監視や適切な運用が不可欠であることを理解した。本インターンシップを通じて、安全なアプリケーション開発とセキュリティ運用に必要な基礎的知識と実践力を身につけることができた。